

Purple Team Handover & Recommendations Report

Project: HawkEye Lab

Objective:

To bridge the gap between offensive (Red Team) findings and defensive (Blue Team) responses, providing actionable recommendations to enhance the overall security posture.

Execution Summary:

- **The Attack (Red Team Focus):** The Red Team successfully exploited an exposed SSH port (Port 22) using a dictionary brute-force attack via Hydra, ultimately gaining root access. This highlighted a critical flaw in password complexity requirements and network exposure.
- **The Defense (Blue Team Focus):** The Blue Team successfully detected the anomaly through log monitoring. The incident response was swift, resulting in the malicious IP being blocked and direct root login being disabled. However, the detection occurred only after the initial breach was successful.

Gap Analysis:

While the Blue Team's containment strategy was effective, the lack of automated rate-limiting allowed the Red Team to execute the brute-force attack uninterrupted until manual intervention occurred. The system relied heavily on reactive measures rather than proactive defense.

Strategic Recommendations:

1. **Implement Fail2Ban (or similar tools):** Automatically ban IP addresses that show malicious signs, such as too many password failures.
2. **Enforce Key-Based Authentication:** Disable password-based SSH logins entirely and mandate SSH cryptographic keys for all administrative access.
3. **Change Default Ports:** Move the SSH service from the default Port 22 to a non-standard port to reduce automated script scans.
4. **Deploy Multi-Factor Authentication (MFA):** Require a secondary authentication method for any internal directory access.

Conclusion:

The HawkEye Lab simulation demonstrated the necessity of proactive defense mechanisms. By implementing the above recommendations, the organization can significantly reduce the attack surface and prevent similar brute-force exploits in the future.